

Botium Toys: Security Audit Case Study

Case Study Background

This scenario was provided as part of the **Google Cybersecurity Professional Certificate** security audit activity. The information below has been condensed from the provided scope, goals, and risk assessment report to document the organization's starting security posture.

This case study served as the basis for my **Controls and Compliance Assessment**.

Audit Scope

The audit covers the overall security program at the fictional company **Botium Toys**, including:

- Employee equipment and end-user devices
- Internal network and internet access
- Business systems and software
- Data retention and storage
- Physical and digital assets
- Legacy systems
- Existing security controls
- Compliance practices

The objective of the activity was to review the organization's assets and current security posture and determine which controls and compliance practices should be implemented or improved.

Current Assets and Environment

Assets managed by the IT department include:

- On-premises equipment supporting in-office operations
- Employee desktops, laptops, smartphones, and remote workstations
- Peripheral equipment and surveillance cameras
- Storefront and warehouse inventory
- Accounting, telecommunications, database, security, e-commerce, and inventory-management systems
- Internet access and the internal network
- Retained and stored organizational data
- Legacy/end-of-life systems requiring human monitoring

Current Security Posture

The provided risk assessment identified **inadequate asset management and significant gaps in security controls and compliance practices**.

Botium Toys received a **risk score of 8 out of 10**, indicating a relatively high level of risk due to insufficient controls and incomplete adherence to compliance best practices.

The potential business impact associated with loss of an asset was rated **medium**, while the risk associated with compromised assets or regulatory fines was rated **high**.

Existing Security Measures

At the beginning of the assessment, Botium Toys had several protections in place:

- A firewall configured to block traffic according to defined security rules
- Antivirus software that was regularly monitored by the IT department
- Controls supporting data availability and integrity
- Physical locks protecting company facilities
- Current CCTV surveillance
- Functioning fire detection and prevention systems
- Privacy policies, procedures, and processes for protecting and maintaining data
- A process for notifying E.U. customers within 72 hours following a security breach
- A password policy
- Monitoring and maintenance of legacy systems

Identified Security Concerns

The provided assessment also documented several areas of concern:

Access Control

All employees had access to internally stored data and potentially to **cardholder information and customer PII/SPII**.

Controls supporting **least privilege and separation of duties had not been implemented**.

Data Protection

Customer credit-card information accepted, processed, transmitted, and stored within the company's internal database was **not encrypted**.

Detection and Monitoring

The organization did **not have an intrusion detection system (IDS)**.

Legacy systems were monitored and maintained, but there was **no regular maintenance schedule**, and intervention procedures were unclear.

Business Continuity and Recovery

Botium Toys had:

- No disaster recovery plan
- No backups of critical data

Password Management

Although a password policy existed, its requirements did not meet current minimum password-complexity practices.

The organization also lacked a **centralized password-management system** capable of enforcing password requirements.

Risk Considerations

The provided risk assessment identified several major areas requiring attention:

- Asset identification and classification
- Protection of cardholder and personally identifiable information
- Access control
- Encryption
- Detection capabilities
- Password management
- Disaster recovery
- Data backups
- Legacy-system management
- Compliance with applicable regulations and security standards

The assessment recommended dedicating resources to identifying and classifying organizational assets and evaluating how the loss of those assets could affect business continuity.

About My Assessment

Using the security posture described above, I completed a **Controls and Compliance Checklist** to evaluate Botium Toys' existing safeguards, identify missing controls, assess relevant compliance considerations, and recommend improvements.